KB 국민카드 정보보호부 | 대외비(Internal Use Only)

주간 정보보호 동향 보고서

2026-11-06 ~ 2026-11-12 · 침해사고대응팀

보고 대상: CEO, CIO(최고정보책임자), CISO(정보보호최고책임자), CPO(개인정보보호책임자), 정보보호부장 | 수집 기준: KST(한국 표준시) 직전 7 일

SECTION 1 — EXECUTIVE SUMMARY

금주 보안 기상도

등급	사유
🔴 위기	카드 결제와 연결된 제 3 자 플랫폼(고위드·자비스) 침해로 복수 카드사 법인카드 부정결제 시도 및 카드번호·빌링키(정기결제 키) 유출이 확인되었고, CISA KEV(Known Exploited Vulnerabilities, 알려진 악용 취약점 목록)에 SonicWall SSL-VPN·Barracuda ESG·OpenSSH 등 경계장비·서버 취약점이 실제 악용으로 등재됨
🟠 경계	금융보안원 정보보호 상시평가 지원시스템이 금융감독원 권한의 허위계정으로 침해되어 48 개 금융회사 관련 자료(개인정보 300 여 건 등)가 유출됨
🟡 주의	금융위원회 580 여 개사 외부접점 전수점검(관리대장 등재 시스템 2026-11-30 기한), 개인정보 유출 2 차 피해 특별대응기간 12 월 말 연장, 가상자산 보안대책 발표

핵심 위협 요약

THIS WEEK IN BRIEF

글로벌에서는 프랑스 Crédit Mutuel Arkéa 가 외부 서비스 제공업체 플랫폼을 경유한 침입으로 약 1 억~1.18 억 유로 규모의 은행 자금 부정이체 피해를 입어, 제 3 자 경유 공격이 직접 금전 피해로 이어진 사례가 확인되었다. 같은 기간 CISA 는 SonicWall SSL-VPN MFA(Multi-Factor Authentication, 다중인증) 우회, Barracuda ESG(Email Security Gateway, 이메일 보안 게이트웨이) 루트 권한 탈취, OpenSSH 인증 우회, Microsoft Outlook 제로데이 등 11 건을 KEV 에 추가했다.

국내에서는 B2B(기업 간 거래) 지출관리 플랫폼 고위드의 관리자 정보 탈취로 여러 카드사에서 법인카드 부정결제가 시도·일부 승인(전량 취소)되었고, 세무·경리 플랫폼 자비스에서는 카드번호·빌링키·공동인증서 정보 유출과 무단결제 15 건이 확인되었다. 금융권 보안관리의 중심축인 금융보안원 상시평가 지원시스템도 금감원 권한 허위계정으로 침해되어 48 개 금융회사 자료가 유출되었다.

규제 측면에서 금융당국은 580 여 개사 외부접점·내부통제 전수점검(등재 시스템 11-30 기한)과 CEO 포함 경영진 책임 추궁 방침을 밝혔고, 개인정보 유출 2 차 피해 특별대응기간을 12 월 말로 연장했다.

당사 관점의 가장 긴급한 조치 사항은 당사 카드와 결제 연동된 제 3 자 플랫폼(고위드·자비스·섹타나인 PG) 관련 거래의 FDS(Fraud Detection System, 이상거래탐지시스템) 룰 강화와 KEV 등재 경계장비(SSL-VPN·이메일 게이트웨이)의 즉시 패치이다.

⚡ 긴급조치 Top 3

1. 고위드·자비스·섹타나인 연동 거래 대상 FDS 긴급 룰(비정상 청구·빌링키 결제) 적용 및 노출 카드 재발급 검토 — FDS 운영팀 / 카드승인시스템
2. SonicWall SSL-VPN(SAML 사용분), Barracuda ESG, OpenSSH(musl·Alpine 기반) 자산 식별 및 긴급 패치, 관리 인터페이스 인터넷 노출 차단 — 인프라보안팀 / 네트워크운영팀
3. 금융보안원 상시평가 지원시스템 내 당사 제출자료·이용자 계정 유출 여부 확인 및 담당 임직원 대상 사칭 피싱 경보 발령 — 정보보호부(관리체계 파트) / CISO 실

SECTION 2 — 사건 및 위협 현황 리스트

수집 사건·동향 총 15 건(심각도 내림차순). 교차검증 기준: ✅ 공식 발표 또는 독립 소스 2 개 이상 / ⚠ 단일 소스.

심각도	위협유형	사건명	피해 주체	발생·공개일	교차검증	금융권 관련성
🔴 CRITICAL	공급망	고위드 지출관리 플랫폼 침해 → 법인카드 부정결제 시도	고위드 고객사, 복수 카드사	2026-11-09	✅	높음
🔴 CRITICAL	공급망	Crédit Mutuel Arkéa 서비스 제공업체 경유 자금 탈취	Crédit Mutuel Arkéa(프랑스)	2026-11-04(후속 2026-11-09)	✅	높음
🔴 CRITICAL	개인정보침해	자비스 해킹 — 카드번호·빌링키·공동인증서 정보 유출, 무단결제 15 건	자비스 이용 기업·임직원	2026-11-06	✅	높음
🔴 CRITICAL	취약점 악용	SonicWall SonicOS SSL-VPN SAML MFA 우회(CVE-2026-19868)	SonicWall Gen7/Gen8 사용 기관	2026-11-06	✅	높음
🔴 CRITICAL	취약점 악용	Barracuda ESG 인증우회+명령주입 체인(CVE-2026-116606/111560)	Barracuda ESG 등 사용 기관	2026-11-10	✅	높음
🔴 CRITICAL	취약점 악용	OpenSSH 비밀번호 인증 우회 "sshole"(CVE-2026-123158)	musl 기반 Linux(Alpine 등)	2026-11-09	✅	중간
🔴 CRITICAL	취약점 악용	MS 11 월 정기패치 — Outlook 제로데이(CVE-2026-124194), Entra CVSS 10.0	Microsoft 365·Office·Entra 사용 기관	2026-11-10	✅	높음
🟠 HIGH	APT·해킹	금융보안원 상시평가 지원시스템 해킹(금감원 권한 허위계정)	금융보안원, 금융회사 48 곳	2026-11-09	✅	높음
🟠 HIGH	개인정보침해	섹타나인 PG 가맹점 관리자 계정 침해 — 구매자명·마스킹 카드번호 유출	섹타나인 PG 이용 고객	2026-11-12	✅	높음
🟠 HIGH	APT·해킹	Storm-3358, AI 공격 프레임워크 ARTEX 로 금융기관 공격	동남아·글로벌 금융기관	2026-11-06	✅	높음
🟡 MEDIUM	정책·제도	금융위 개인정보 유출 2 차 피해 특별대응기간 12 월 말 연장	전 금융권	2026-11-06	✅	높음
🟡 MEDIUM	정책·제도	금융위 가상자산업권 보안대책(해킹 의심 시 입출금 선제 차단)	가상자산사업자	2026-11-12	✅	낮음
🟡 MEDIUM	정책·제도	AI 시대 全금융권 보안체계 혁신방안(580 여 개사 전수점검)	전 금융권	2026-11-05(예외)	✅	높음
🟡 MEDIUM	APT·해킹	Binance 탈취자금 밈코인 활용 세탁 정황(Elliptic 분석)	Binance, 가상자산 생태계	2026-11-09	✅	낮음
🟡 MEDIUM	피싱·사회공학	견적서 문의 위장 피싱 메일(SnakeKeylogger) 유포	국내 기업 구매 담당자	2026-11-12	⚠	중간

SECTION 3 — 위협 유형별 통계

위협유형	건수	심각도 분포
취약점 악용	4	🔴 4
공급망	2	🔴 2
개인정보침해	2	🔴 1 / 🟠 1

위협유형	건수	심각도 분포
APT·해킹	3	🟠 2 / 🟡 1
정책·제도	3	🟡 3
피싱·사회공학	1	🟡 1
총계	15	🔴 7 / 🟠 3 / 🟡 5

※ 랜섬웨어·DDoS(Distributed Denial of Service, 분산 서비스 거부)는 수집 기간 내 금융권 관련 신규 사건이 확인되지 않아 표에서 제외함.

SECTION 4 — 주요 사건 상세 보고

SECTION 2 중 금융권 영향도·심각도가 높은 7 건을 상세 분석한다. MITRE ATT&CK(공격자 전술·기법 지식베이스) ID 를 병기한다.

🔴 CRITICAL [공급망] 고위드 지출관리 플랫폼 — 관리자 정보 탈취 후 위조 청구로 법인카드 부정결제

사건 개요

B2B 법인카드·지출관리 핀테크 고위드의 "지출최적화" 서비스(구글 워크스페이스 구독료 청구·결제 기능)가 침해되어, 공격자가 해당 서비스 관리자 정보를 탈취한 뒤 가짜 전자문서로 결제를 요청했다. 여러 카드사에서 부정결제가 시도되었고 일부는 승인되었으나 고위드가 승인 건 전부를 취소했으며, 카드사들은 FDS 로 추가 결제를 차단하고 해당 법인카드를 재발급했다. 보도 기준 실제 자금 유출은 없다.

- 누가: 공격 주체 조사 중 / 피해 주체 고위드 및 고객사, 복수 카드사
- 언제: 침해 발생 2026-10-27, 최초 보도 2026-11-09
- 어디서: 고위드 지출최적화 서비스 청구·결제 기능(대한민국)
- 무엇을: 서비스 관리자 정보, 고객사 담당자 개인정보·청구 정보, 법인카드 결제
- 어떻게: 관리자 계정 정보 탈취 → 위조 전자문서 기반 결제 요청
- 얼마나: 피해 고객사 수·시도 금액 미공개, 금전 피해 없음(승인 건 전량 취소)

메타데이터

[필수]

- 발생·공개일: 2026-10-27(발생) / 2026-11-09(공개)
- 공격 유형: T1078 Valid Accounts(유효 계정 악용), T1199 Trusted Relationship(신뢰관계 악용), T1657 Financial Theft(금전 탈취)
- 피해 규모: 조사 중(실제 자금 유출 없음)

[조건부]

- 유출 항목: 고객사 담당자 개인정보, 청구 관련 정보
- 관련 규제: 전자금융거래법 제 9 조(금융회사 등의 책임), 개인정보 보호법 제 34 조(유출 통지·신고) — 고위드는 금감원 직접 검사 대상이 아님(보도)

출처 및 교차확인

- 출처 1: [T4] 한국경제 / 새 빈틈 파고든 해커…금융 플랫폼 통해 법카 부정결제 잇따라 / 2026-11-09 / https://www.hankyung.com/article/2026110960607
- 출처 2: [T4] 매일일보 / 법인카드 관리 플랫폼 해킹… 카드사 여러 곳서 부정결제 시도 / 2026-11-09 / https://www.m-i.kr/news/articleView.html?idxno=2016413
- 출처 3: [T4] 재경일보 / 고위드 해킹에 법인카드 부정결제 시도…금전피해 없어 / 2026-11-10 / https://news.jkn.co.kr/post/1081588
- 교차확인: ✅ 확인 (3 개 소스 / 최고 신뢰도: T4)

💳 금융권 시사점

KB 국민카드 관점

[리스크] 복수 카드사에서 부정 승인이 실제로 발생했다. 플랫폼이 감독 사각지대에 있더라도 승인 주체인 카드사는 전자금융거래법 제 9 조상 이용자 손해 책임 및 FDS 운영 적정성을 근거로 감독 대상이 되며, 반복 시 금융위가 밝힌 경영진 책임 추궁 방침과 연결될 수 있다.

[영향] 당사 법인카드가 고위드 등 지출관리 플랫폼에 등록되어 있는 경우, 동일 기법(관리자 계정 탈취 후 위조 청구)으로 정상 가맹점 명의의 반복 청구가 승인될 수 있으며, 이는 정상 거래 패턴과 유사해 기존 FDS 룰로 탐지가 늦어질 수 있다.

[조치] ① FDS 운영팀: 고위드 및 유사 B2B 지출관리 플랫폼 경유 법인카드 거래의 금액·빈도 급변 룰 즉시 적용, 승인 건 소급 점검. ② 법인영업·제휴관리팀: 법인카드 대량 등록 플랫폼 목록화 및 침해 통지 의무·관리자 MFA 적용 여부 확인.

🔴 CRITICAL [공급망] Crédit Mutuel Arkéa — 서비스 제공업체 플랫폼 경유로 약 1억 유로 자금 부정이체

사건 개요

프랑스 협동조합 은행그룹 Crédit Mutuel Arkéa는 외부 서비스 제공업체 플랫폼을 통해 공격자가 내부에 접근했고, 이후 은행 자체 계좌에서 부정이체가 발생했다고 밝혔다. 은행은 보도된 1.18억 유로(약 1.33억 달러)의 "규모 수준"이 맞다고 했고, Reuters 인용 보도는 은행 추정치를 약 1억 유로로 전했다. 자금은 타 은행으로 이체 후 가상자산으로 전환되었으며, 고객 자산 피해는 없고 일부 이체 지연이 있었다. 파리 검찰 사이버범죄부가 수사에 착수했다.

- 누가: 공격 주체 미공개(책임 주장 그룹 없음) / 피해 주체 Crédit Mutuel Arkéa
- 언제: 2026-11-04 공개, 2026-11-09 후속 보도
- 어디서: 외부 서비스 제공업체 플랫폼(업체명 미공개), 프랑스
- 무엇을: 은행 자체 자금
- 어떻게: 서비스 제공업체 플랫폼 경유 접근 → 부정 송금 → 가상자산 전환
- 얼마나: 약 1억~1.18억 유로(최종 확정 전)

메타데이터

[필수]

- 발생·공개일: 2026-11-04
- 공격 유형: T1199 Trusted Relationship, T1657 Financial Theft
- 피해 규모: 약 1억~1.18억 유로(은행 최종 산정 중)

[조건부]

- 관련 규제: (해외) EU DORA 등 적용 여부 조문 확인 필요 / (당사 준용) 전자금융감독규정상 외부주문(아웃소싱) 관리 — 조문 확인 필요

출처 및 교차확인

- 출처 1: [T3] BleepingComputer / Hackers pull off $133 million French bank heist via service provider / 2026-11-05 / https://www.bleepingcomputer.com/news/security/hackers-pull-off-133-million-french-bank-heist-via-service-provider/
- 출처 2: [T3] Security Affairs / Attackers Exploit Third-Party Provider to Raid French Bank Crédit Mutuel Arkéa / 2026-11-06 / https://securityaffairs.com/202628/cyber-crime/attackers-exploit-third-party-provider-to-raid-french-bank-credit-mutuel-arkea.html
- 출처 3: [T3] Hackread / Hackers Steal €100M From Crédit Mutuel Arkéa Through Supplier Platform / 2026-11-09 / https://hackread.com/hackers-steal-e100m-credit-mutuel-arkea-supplier-platform/
- 교차확인: ✅ 확인 (은행 공식 발표 + 3개 소스 / 최고 신뢰도: T3)

💳 금융권 시사점

KB 국민카드 관점

[리스크] 제3자 플랫폼 경유로 내부통제 우회 후 수천억 원대 직접 손실이 발생한 사례이다. 국내에서는 전자금융거래법 제21조(안전성 확보 의무)와 외부주문 관리 규정이 수탁사 통제 책임을 금융회사에 부과하므로, 유사 사고 시 재무 손실과 감독 제재가 동시에 발생할 수 있다.

[영향] 당사 자금이체·정산 업무에 외부 서비스 제공업체(정산 대행, 펌뱅킹, SaaS형 재무 솔루션)가 연결되어

있는 경우, 해당 업체 계정이 탈취되면 당사 명의의 대량 송금이 정상 경로로 실행될 수 있다.

[조치] ① 재무·자금 IT 담당: 외부업체 경유 송금의 이중 승인(Out-of-band 확인)·건별 한도·야간 이체 차단 규칙 점검. ② 정보보호부: 자금 관련 수탁사 접근 계정 전수 재인증 및 접속 로그 30 일 소급 점검.

🔴 CRITICAL [개인정보침해] 자비스(세무·경리 플랫폼) — 카드번호·빌링키·공동인증서 정보 유출 및 무단결제 15 건

사건 개요

세무법인 에스브이가 운영하는 세무·경리 플랫폼 자비스에 2026-11-02~11-05 외부 해커가 불법 접근했다. 운영사는 당초 사칭 메일로 안내했으나 이후 실제 침입과 개인정보 유출을 확인했다. 대표자·임직원 개인정보, 급여 정보, 카드번호, 정기결제용 빌링키, 공동인증서 정보의 유출 또는 유출 가능성이 공지되었고, 무단결제 15 건이 확인되어 취소(환불)되었다. 운영사는 서비스 전체를 중지하고 결제를 차단했으며 PG(Payment Gateway, 전자결제대행)사와 협의해 빌링키를 폐기했다.

- 누가: 공격 주체 조사 중 / 피해 주체 자비스 이용 기업 대표자·임직원
- 언제: 침입 2026-11-02~11-05, 인지 2026-11-05, 보도 2026-11-06
- 어디서: 자비스 서비스(대한민국)
- 무엇을: 개인정보, 급여 정보, 카드번호, 빌링키, 공동인증서 정보
- 어떻게: 외부 불법 접근(세부 기법 조사 중)
- 얼마나: 유출 인원 미공개, 무단결제 15 건(전액 취소)

메타데이터

[필수]

- 발생·공개일: 2026-11-05(인지) / 2026-11-06(공개)
- 공격 유형: 조사 중(확인된 결과: T1657 Financial Theft)
- 피해 규모: 무단결제 15 건, 유출 인원 조사 중

[조건부]

- 유출 항목: 이름·주민등록번호 등 대표자 정보, 급여 정보, 카드번호, 빌링키, 공동인증서 정보(비밀번호·개인키 포함 여부 미공개)
- 관련 규제: 개인정보 보호법 제 34 조(유출 통지·신고 — 개인정보위·KISA(한국인터넷진흥원) 신고 완료), 제 29 조(안전조치의무)

출처 및 교차확인

- 출처 1: [T3] 데일리시큐 / 세무·경리 플랫폼 자비스 해킹, 기업 대표자 주민번호부터 급여·결제·공동인증서 정보까지 유출 우려 / 2026-11-06 / https://www.dailysecu.com/news/articleView.html?idxno=209356
- 출처 2: [T3] 보안뉴스 / '사칭'이라던 자비스, 실제 뚫렸다… 공동인증서·결제 정보 등 유출 확인 / 2026-11-06 / https://www.boannews.com/news/articleView.html?idxno=147080
- 교차확인: ✅ 확인 (운영사 공지 + 2 개 소스 / 최고 신뢰도: T3)

💳 금융권 시사점

KB 국민카드 관점

[리스크] 빌링키는 카드 인증정보 재입력 없이 정기결제를 일으킬 수 있는 키로, 유출 시 카드사 승인 단계에서 정상 결제와 구분이 어렵다. 실제 무단결제가 발생했으므로 카드사는 여신전문금융업법상 부정사용 보상 책임(조문 확인 필요)과 민원 리스크를 부담한다.

[영향] 당사 개인·법인카드가 자비스에 정기결제 수단으로 등록된 경우, 폐기 전 빌링키 또는 유출 카드번호로 타 가맹점 비대면 결제가 시도될 수 있고, 유출된 대표자 주민번호·급여 정보는 법인카드 재발급·한도 상향 요청 사칭(사회공학)에 악용될 수 있다.

[조치] ① FDS 운영팀: 자비스(세무법인 에스브이) 가맹점 결제 이력 보유 카드 추출 → 비대면 결제 모니터링 강화 및 재발급 안내. ② 고객센터: 법인 대표자 명의 변경·재발급 요청 시 추가 본인확인 절차 일시 적용.

🔴 CRITICAL [취약점 악용] SonicWall SonicOS SSL-VPN(CVE-2026-19868) — SAML MFA 우회 실제 악용

사건 개요

SonicWall SonicOS SSL-VPN(Secure Sockets Layer VPN, 원격접속 가상사설망)의 인증 강제 결함으로, SAML(Security Assertion Markup Language, 통합인증 표준)을 SSL-VPN 로그인에 사용하는 환경에서 다른 로그인 방식의 유효 자격증명을 가진 공격자가 SAML 강제 MFA 를 우회할 수 있다. CISA 는 2026-11-06 KEV 에 등재했으며 연방기관 조치기한은 2026-11-20 이다. SonicWall 은 공격 세부·IOC(Indicator of Compromise, 침해지표)를 공개하지 않았고 우회책 없이 패치를 권고했다.

- 누가: 공격 주체 미공개 / 피해 주체 SonicWall Gen7·Gen8 사용 기관
- 언제: 2026-11-06 KEV 등재
- 어디서: SonicOS SSL-VPN 서비스(전 세계)
- 무엇을: VPN 인증(MFA)
- 어떻게: 유효 자격증명 + SAML 강제 우회
- 얼마나: 피해 기관 수 미공개

메타데이터

[필수]

- 발생·공개일: 2026-11-06
- 공격 유형: T1133 External Remote Services(외부 원격 서비스), T1556 Modify Authentication Process(인증 절차 우회), T1078 Valid Accounts
- 피해 규모: 조사 중

[조건부]

- CVE: CVE-2026-19868 (CVSS 7.1 / High)
- 영향 버전: Gen7 7.3.3-7015 이하, Gen8 8.2.2-8015 이하 (수정: 7.3.4-7013, 8.2.3-8015)
- CISA KEV 등재 여부: 예
- 패치 기한: 2026-11-20(CISA 연방기관 기준)

출처 및 교차확인

- 출처 1: [T1] CISA / CISA Adds One Known Exploited Vulnerability to Catalog / 2026-11-06 / https://www.cisa.gov/news-events/alerts/2026/11/06/cisa-adds-one-known-exploited-vulnerability-catalog
- 출처 2: [T3] SecurityWeek / SonicWall Patches Exploited SonicOS Vulnerability That Weakens VPN Logins / 2026-11 / https://www.securityweek.com/sonicwall-patches-exploited-sonicos-bug-that-weakens-vpn-logins/
- 출처 3: [T3] Help Net Security / Exploited SonicWall SSL-VPN flaw lets attackers bypass SAML-enforced MFA / 2026-11-09 / https://www.helpnetsecurity.com/2026/11/09/exploited-sonicwall-ssl-vpn-flaw-lets-attackers-bypass-saml-enforced-mfa-cve-2026-19868/
- 교차확인: ✅ 확인 (3 개 소스 / 최고 신뢰도: T1)

💳 금융권 시사점

KB 국민카드 관점

[리스크] MFA 는 전자금융감독규정상 원격접속 통제의 핵심 요건이다. 우회가 가능한 상태로 운영 시 금융위 전수점검(외부접점) 과정에서 중대 취약점으로 분류되어 서비스 중단·외부 접근 차단 조치 대상이 될 수 있다.

[영향] 당사 또는 협력사(콜센터·유지보수 업체)가 SAML 연동 SonicWall SSL-VPN 을 사용하는 경우, 크리덴셜

스터핑·유출 계정과 결합해 MFA 없이 내부망에 접근할 수 있으며, 최근 금융권 연쇄 침해의 주요 경로인 외부접점과 동일 유형이다.

[조치] ① 네트워크운영팀: SonicWall 자산·펌웨어 버전 즉시 확인 및 수정 버전 적용, SAML 외 로그인 방식 비활성화. ② 정보보호부: 협력사 원격접속 장비 현황 질의 및 VPN 로그의 비정상 인증 성공 이력 점검.

🔴 CRITICAL [취약점 악용] Barracuda ESG(CVE-2026-116606·111560) — 비인증 루트 권한 탈취 체인 악용

사건 개요

Barracuda 는 2026-11-09 권고문을 갱신해 ESG 의 인증우회(CVE-2026-116606)와 명령주입(CVE-2026-111560) 취약점이 "소수 조직"을 대상으로 악용되고 있다고 밝혔고, CISA 는 2026-11-10 두 취약점을 KEV 에 등재했다. 두 취약점을 연결하면 관리자 인터페이스에 접근 가능한 공격자가 조작된 백업 아카이브 복원으로 설정을 변경하고, 시간대 설정 필드의 셸 메타문자 미처리를 이용해 루트 권한으로 명령을 실행할 수 있다.

- 누가: 공격 주체 미공개 / 피해 주체 Barracuda ESG 사용 조직
- 언제: 2026-11-09 악용 확인, 2026-11-10 KEV 등재
- 어디서: Barracuda ESG 관리자 인터페이스(CVE-2026-111560 은 WAF·ADC·WSG 등 영향)
- 무엇을: 이메일 보안 게이트웨이 장비 전체 권한
- 어떻게: 인증우회 → OS 명령주입(루트)
- 얼마나: 2026-11-09~11 15 개 IP 에서 17 회 공격 시도 관측(Previdian)

메타데이터

[필수]

- 발생·공개일: 2026-11-10
- 공격 유형: T1190 Exploit Public-Facing Application(공개 애플리케이션 취약점 악용), T1059 Command and Scripting Interpreter(명령 실행), T1068 Exploitation for Privilege Escalation
- 피해 규모: "소수 조직"(Barracuda), 수치 미공개

[조건부]

- CVE: CVE-2026-116606 (CVSS 9.3 / Critical), CVE-2026-111560 (CVSS 8.6 / High)
- 영향 버전: Barracuda 권고문 기준 확인 필요
- CISA KEV 등재 여부: 예(2026-11-10)
- 패치 기한: CISA 카탈로그 기준 확인 중

출처 및 교차확인

- 출처 1: [T1] CISA / CISA Adds Six Known Exploited Vulnerabilities to Catalog / 2026-11-10 / https://www.cisa.gov/news-events/alerts/2026/11/10/cisa-adds-six-known-exploited-vulnerabilities-catalog
- 출처 2: [T3] SecurityWeek / Recently Patched Barracuda Vulnerabilities Exploited in Attacks / 2026-11-11 / https://www.securityweek.com/recently-patched-barracuda-vulnerabilities-exploited-in-attacks/
- 교차확인: ✅ 확인 (제조사 공식 권고 + 2 개 소스 / 최고 신뢰도: T1)

💳 금융권 시사점

KB 국민카드 관점

[리스크] 이메일 게이트웨이는 고객·임직원 메일과 첨부파일이 통과하는 지점으로, 장악 시 메일 열람·위변조가 가능하다. 개인정보·신용정보가 포함된 메일이 노출될 경우 개인정보 보호법 제 34 조, 신용정보법 제 39 조의 4(누설 통지) 대응 의무가 발생한다.

[영향] 당사 또는 이메일 위탁 운영사가 Barracuda ESG·WAF 를 사용하고 관리자 인터페이스가 인터넷에 노출된

경우, 비인증 공격자가 루트 권한으로 메일 흐름을 장악해 내부 임직원 대상 피싱 발송 거점으로 악용할 수 있다.

[조치] ① 인프라보안팀: Barracuda 제품 사용 여부 확인, 최신 업데이트 적용 및 관리자 인터페이스를 내부 신뢰망으로 제한. ② 보안관제팀: 장비 설정 변경·백업 복원 이력과 비정상 아웃바운드 연결 점검.

🔴 CRITICAL [취약점 악용] OpenSSH "sshole"(CVE-2026-123158) — 공개 9 시간 만에 실제 악용, KEV 등재

사건 개요

OpenSSH 10.6p2 미만에서 musl C 라이브러리를 사용하고 PAM(Pluggable Authentication Modules, 플러그형 인증 모듈)으로 비밀번호를 검증하지 않는 Linux(Alpine 기본 openssh-server, OpenWrt·Buildroot·Yocto 등)에서 비밀번호 인증을 우회할 수 있다. 2026-11-05 공개 후 9 시간 이내 첫 공격 시도가 관측되었고, GreyNoise 는 2026-11-07 첫 성공 공격을 관측했다. KISA 는 2026-11-07 보안 업데이트를 권고했으며 CISA 는 2026-11-09 KEV 에 등재했다.

- 누가: 공격 주체 미공개 / 피해 주체 musl 기반 Linux 운영 조직
- 언제: 2026-11-05 공개, 2026-11-07 KISA 권고, 2026-11-09 KEV 등재
- 어디서: SSH 서비스(컨테이너 이미지·임베디드 장비 포함)
- 무엇을: 서버 원격 접속 권한(허니팟에서 루트 획득 사례 보고)
- 어떻게: 비밀번호 인증 우회
- 얼마나: 2026-11-08 까지 13 개 IP 에서 20 회 시도 관측

메타데이터

[필수]

- 발생·공개일: 2026-11-05(공개) / 2026-11-09(KEV)
- 공격 유형: T1190 Exploit Public-Facing Application, T1021.004 Remote Services: SSH
- 피해 규모: 조사 중

[조건부]

- CVE: CVE-2026-123158 (CVSS 미확인)
- 영향 버전: OpenSSH 10.6p2 미만 + musl libc + 비 PAM 비밀번호 검증
- CISA KEV 등재 여부: 예
- 패치 기한: 2026-11-12(CISA 연방기관 기준)

출처 및 교차확인

- 출처 1: [T1] CISA / CISA Adds Four Known Exploited Vulnerabilities to Catalog / 2026-11-09 / https://www.cisa.gov/news-events/alerts/2026/11/09/cisa-adds-four-known-exploited-vulnerabilities-catalog
- 출처 2: [T3] 데일리시큐 / 오픈 SSH 인증 우회 취약점 공개 9 시간 만에 실제 공격…KISA 도 7 일 보안 업데이트 권고 / 2026-11-07 / https://www.dailysecu.com/news/articleView.html?idxno=209393
- 출처 3: [T3] Help Net Security / OpenSSH flaw exploited in the wild just hours after disclosure / 2026-11-06 / https://www.helpnetsecurity.com/2026/11/06/openssh-sshole-cve-2026-123158-exploitation/
- 교차확인: ✅ 확인 (KISA·CISA 공식 + 독립 소스 / 최고 신뢰도: T1)

💳 금융권 시사점

KB 국민카드 관점

[리스크] Alpine 기반 컨테이너는 클라우드·MSA(Microservice Architecture, 마이크로서비스 구조) 환경에 광범위하게 쓰인다. 고객정보 처리 시스템 침해로 이어질 경우 신용정보법·전자금융거래법상 안전성 확보 의무 위반 쟁점이 발생한다.

[영향] 당사 앱·API(Application Programming Interface) 서버나 개발·배포 환경에 SSH 가 활성화된 Alpine 이미지가 있고 비밀번호 인증이 허용된 경우, 외부 또는 내부 횡적 이동 경로에서 인증 없이 셸을 획득당할 수 있다.

[조치] ① 클라우드·플랫폼운영팀: 컨테이너 레지스트리·네트워크 장비 대상 musl 기반 OpenSSH 버전 스캔, 10.6p2 이상 적용 전까지 PasswordAuthentication no 설정. ② DevSecOps: 베이스 이미지 재빌드 및 이미지 스캐너 정책에 해당 CVE 차단 규칙 추가.

🟠 HIGH [APT·해킹] 금융보안원 상시평가 지원시스템 — 금감원 권한 허위계정으로 48 개 금융회사 자료 유출

사건 개요

금융보안원은 2026-11-09 정보보호 상시평가 지원시스템에 대한 외부의 비정상 접근을 확인하고 접속을 차단했다. 공격자는 금융보안원의 권한 승인 시스템 취약점을 이용해 금융감독원 권한을 가진 허위 계정을 만들어 접속했고, 수백 개 IP 를 바꿔가며 접근한 것으로 보도되었다. 48 개 금융회사 관련 파일 130 여 개(행정서식 약 200 건, 이름·생년월일 등 개인정보 300 여 건, 시스템 이용자 정보 350 여 건)가 유출되었으며, 금융보안원은 금융회사 시스템 구성도 등 보안정보와 금융고객 민감정보 유출은 현재까지 확인되지 않았다고 밝혔다. 서울경찰청 사이버수사대가 수사에 착수했고 금융위·금감원은 현장점검에 들어갔다.

- 누가: 공격 주체 조사 중(경찰 수사) / 피해 주체 금융보안원 및 금융회사 48 곳
- 언제: 2026-11-09 비정상 접근 확인·차단, 2026-11-10~11 보도
- 어디서: 금융보안원 정보보호 상시평가 지원시스템(대한민국)
- 무엇을: 행정서식, 금융회사 직원 개인정보, 시스템 이용자 정보
- 어떻게: 권한 승인 절차 취약점 악용 → 금감원 권한 허위계정 생성 → 다수 IP 순환 접속
- 얼마나: 파일 130 여 개, 개인정보 300 여 건 + 이용자 정보 350 여 건(48 개사)

메타데이터

[필수]

- 발생·공개일: 2026-11-09
- 공격 유형: T1136 Create Account(계정 생성), T1078 Valid Accounts, T1090 Proxy(IP 우회), T1213 Data from Information Repositories
- 피해 규모: 48 개 금융회사, 개인정보 약 650 건

[조건부]

- 유출 항목: 개인신용정보 동의서 샘플 등 행정서식, 이름·생년월일, 일부 마스킹된 이름·휴대전화번호·이메일
- 관련 규제: 개인정보 보호법 제 34 조(유출 통지·신고), 전자금융거래법 제 21 조의 5(침해사고 통지) — 금융보안원 적용 범위 조문 확인 필요

출처 및 교차확인

- 출처 1: [T4] 뉴스 1 / 금감원 사칭 계정으로 금융보안원 뚫었다…경찰도 수사 착수(종합) / 2026-11-10 / https://www.news1.kr/finance/bank/6350751
- 출처 2: [T4] 서울신문 / 금융보안원도 해킹당했다… 금융사 보안 정보 일부 유출 / 2026-11-11 / https://seoul.co.kr/news/economy/finance/2026/11/11/20261111029004
- 출처 3: [T4] 알파경제 / 금융보안원마저 해킹에 뚫렸다…48 개사 자료 유출·경찰 수사 / 2026-11-10 / https://www.alphabiz.co.kr/news/articleView.html?idxno=197558
- 교차확인: ✅ 확인 (금융보안원 공식 발표 + 3 개 소스 / 최고 신뢰도: T4)

💳 금융권 시사점

KB 국민카드 관점

[리스크] 금융권 공동 보안 인프라가 침해되어 금융회사 보안 담당자 정보가 노출되었다. 유출된 이용자 정보(담당자 성명·연락처)는 금감원·금보원 사칭 표적 피싱의 기초 자료가 될 수 있으며, 당사가 48 개사에 포함된 경우 개인정보 보호법 제 34 조에 따른 임직원 통지 대응이 필요하다.

[영향] 당사 정보보호 담당자 정보가 유출 대상에 포함된 경우, 공격자가 금감원·금보원을 사칭해 "상시평가 자료 재제출" 등을 명목으로 내부 문서·계정 정보를 요구하는 표적 피싱을 시도할 수 있다. 시스템 구성도 등 보안정보 유출은 현재 미확인이나 추가 조사 결과에 따라 범위가 확대될 수 있다.

[조치] ① 정보보호부(관리체계 파트): 금융보안원에 당사 유출 여부·항목 공식 확인 요청, 상시평가 시스템 계정 비밀번호 변경. ② 보안관제팀: 감독기관 도메인 유사 발신 메일 차단 룰 및 담당자 대상 사칭 주의 공지 즉시 시행.

SECTION 5 — 즉시 조치 권고

우선순위	조치 항목	담당 부서/시스템	완료 기한	근거 사건
🔴 1 순위	고위드·자비스·섹타나인 연동 카드 거래 FDS 긴급 룰 적용, 무단결제 소급 점검 및 재발급 안내	FDS 운영팀 / 카드승인시스템	즉시	고위드·자비스·섹타나인
🔴 1 순위	SonicWall SSL-VPN 펌웨어 7.3.4-7013 / 8.2.3-8015 이상 적용, VPN 인증 로그 점검	네트워크운영팀	즉시	CVE-2026-19868
🔴 1 순위	Barracuda ESG·WAF 업데이트 및 관리자 인터페이스 외부 차단	인프라보안팀	즉시	CVE-2026-116606/111560
🔴 1 순위	musl 기반 OpenSSH 10.6p2 이상 적용 또는 비밀번호 인증 비활성화	클라우드·플랫폼운영팀	즉시	OpenSSH sshole
🔴 1 순위	Outlook(M365 Apps, Office LTSC 2021/2024) 11 월 패치 우선 배포, 아웃바운드 SMB/NTLM 차단 점검	사내 IT 운영팀 / PC 보안	즉시	CVE-2026-124194
🟠 2 순위	금융보안원 상시평가 시스템 당사 유출 여부 확인, 담당자 계정 비밀번호 변경, 감독기관 사칭 메일 차단	정보보호부(관리체계) / 보안관제팀	금주 내	금융보안원 해킹
🟠 2 순위	자금이체·정산 연계 외부업체 접근 계정 재인증, 송금 이중승인·한도 점검	재무 IT / 정보보호부	금주 내	Crédit Mutuel Arkéa
🟠 2 순위	Entra(Azure AD) 장치 등록 관련 MSRC 권고 확인 및 조치 여부 검증	클라우드보안 담당	금주 내	Entra CVSS 10.0
🟠 2 순위	금융위 전수점검 대응: 관리대장 등재 외부접점 시스템 취약점 점검 결과 보고 준비	정보보호부 / IT 기획팀	2026-11-30	보안체계 혁신방안
🟡 3 순위	법인카드 대량 등록 B2B 플랫폼·PG 제휴사 보안 실사 (관리자 MFA, 침해 통지 조항) 계획 수립	제휴관리팀 / 정보보호부	이달 내	고위드·섹타나인
🟡 3 순위	AI 기반 공격(ARTEX) 대비 외부 노출 자산 SSRF·파일업로드 취약점 점검 및 RAT 탐지 룰 반영	보안관제팀 / 웹보안	이달 내	Storm-3358
🟡 3 순위	개인정보 유출 2 차 피해 특별대응기간(12 월 말) 연계 고객 보이스피싱·스미싱 안내 지속	소비자보호부 / 고객센터	이달 내	특별대응기간 연장

※ NTLM(NT LAN Manager, 윈도우 인증 프로토콜), SMB(Server Message Block, 파일공유 프로토콜), MSRC(Microsoft Security Response Center), SSRF(Server-Side Request Forgery, 서버측 요청 위조), RAT(Remote Access Trojan, 원격제어 악성코드).

SECTION 6 — 사고 개별 분석 리포트

작성 대상: 금융권 직결 사건 중 경영진 의사결정이 필요한 3 건

[보고] 금융보안원 상시평가 지원시스템 해킹 사고 분석 및 대응 리포트

1. 사고 개요 및 규모

- 발견 시점: 2026-11-09 (금융보안원 자체 탐지 — 외부의 비정상 접근 확인)
- 유출·피해 규모: 48 개 금융회사 관련 파일 130 여 개, 개인정보 300 여 건 + 시스템 이용자 정보 350 여 건 (일부 보도는 상시평가 대상 약 3,000 개사 중 30~40 개사로 집계, 집계 기준 상이)
- 피해 항목: 개인신용정보 동의서 샘플 등 행정서식, 이름·생년월일, 일부 마스킹된 이름·휴대전화번호·이메일 / 시스템 구성도·고객 민감정보 유출은 미확인

2. 사고 원인 및 경위

- 공격 유형: 권한 승인 절차 취약점을 이용한 허위 계정 생성(T1136), 유효 계정 악용(T1078), 다수 IP 순환 접속(T1090)
- 기술적 원인: 권한 승인 시스템이 감독기관(금감원) 권한 계정 생성 요청을 충분히 검증하지 못함 / 관리적 원인: 고권한 계정 발급 시 기관 간 교차 확인 절차의 실효성 조사 중
- 발견 배경: 금융보안원이 비정상 외부 접근을 확인 후 접속 차단 및 경찰 수사 의뢰, 2026-11-10 언론 보도
- 발생 추정 시점: 조사 중 (실제 금감원 계정 정보 유출·사용 정황은 미확인 — 뉴스 1)

3. 현재 대응 상황

- 즉시 대응: 시스템 접속 차단(금융보안원)
- 보안 강화: 조사 중(공식 발표 미공개)
- 유관기관 신고: 서울경찰청 사이버수사대 수사 착수, 금융위원회·금융감독원 현장점검

4. 경영진 제언

비즈니스 리스크

- 법적·규제: 당사가 48 개사에 포함된 경우 개인정보 보호법 제 34 조에 따른 임직원 정보주체 통지 대응 필요. 감독기관 공동 인프라 신뢰 저하로 상시평가 제출 절차 변경 가능성 존재
- 평판·고객: 고객 민감정보 유출은 미확인으로 직접 고객 영향은 제한적이나, 금융권 연쇄 침해 보도 흐름 속에서 언론 노출 시 평판 부담
- 재무·운영: 유출 담당자 정보를 이용한 감독기관 사칭 표적 피싱 성공 시 내부망 침투 → 고객정보 유출로 확대될 수 있음

대응 전략

> **대응 로드맵**
>
> **즉시 (24 시간 이내):** 금융보안원에 당사 유출 여부·항목 공식 확인 요청, 상시평가 시스템 계정 비밀번호 변경, 감독기관 사칭 메일 차단 룰 적용(보안관제팀)
>
> **단기 (1~2 주 이내):** 대외기관 제출 자료 분류 기준 재정립(시스템 구성도 등 민감 보안정보는 오프라인·암호화 제출), 정보보호부·IT 기획팀 임직원 대상 표적 피싱 모의훈련(정보보호부)
>
> **중장기 (1 분기 이내):** 외부 기관 포털 계정 전수 관리대장화 및 정기 재인증, 위협 인텔리전스 공유 채널 다변화 — 위협정보 플랫폼 예산 반영 검토(CISO 실)

5. 관련 출처

- [T4] 뉴스 1 / 금감원 사칭 계정으로 금융보안원 뚫었다…경찰도 수사 착수(종합) / 2026-11-10 / https://www.news1.kr/finance/bank/6350751

- [T4] 서울신문 / 금융보안원도 해킹당했다… 금융사 보안 정보 일부 유출 / 2026-11-11 / https://seoul.co.kr/news/economy/finance/2026/11/11/20261111029004
- [T4] 알파경제 / 금융보안원마저 해킹에 뚫렸다…48 개사 자료 유출·경찰 수사 / 2026-11-10 / https://www.alphabiz.co.kr/news/articleView.html?idxno=197558
- [T4] Korea JoongAng Daily / Financial Security Institute reports data leak following hacking attack / 2026-11-10 / https://www.koreajoongangdaily.com/business/financial-security-institute-reports-data-leak-following-hacking-attack/12966269

[보고] 고위드 지출관리 플랫폼 경유 법인카드 부정결제 사고 분석 및 대응 리포트

1. 사고 개요 및 규모

- 발견 시점: 2026-10-27 침해 발생 (고위드 및 카드사 FDS 탐지), 2026-11-09 언론 공개
- 유출·피해 규모: 복수 카드사에서 부정결제 시도, 일부 승인 → 전량 취소, 실제 자금 유출 없음 (피해 고객사 수·시도 금액 미공개)
- 피해 항목: 고객사 담당자 개인정보, 청구 관련 정보

2. 사고 원인 및 경위

- 공격 유형: 서비스 관리자 정보 탈취 후 위조 전자문서로 결제 요청 — T1078 Valid Accounts, T1199 Trusted Relationship, T1657 Financial Theft
- 기술적 원인: 지출최적화 서비스(구글 워크스페이스 구독료 청구·결제) 관리자 정보 탈취 경로 조사 중 / 관리적 원인: B2B 핀테크가 금감원 직접 검사 대상이 아닌 감독 공백(보도)
- 발견 배경: 카드사 FDS 탐지 및 고위드 자체 확인, 금감원은 부정결제 발생 개별 금융사를 통해 경위 파악 중
- 발생 추정 시점: 2026-10-27 (한국경제)

3. 현재 대응 상황

- 즉시 대응: 고위드의 승인 건 전량 취소, 카드사 FDS 추가 결제 차단·승인 취소
- 보안 강화: 부정결제 발생 카드사의 해당 고객사 법인카드 재발급
- 유관기관 신고: 금융감독원 경위 파악(개별 금융사 경유) / 개인정보위 신고 여부 미공개

4. 경영진 제언

비즈니스 리스크

- 법적·규제: 승인 주체인 카드사는 전자금융거래법 제 9 조상 이용자 손해 책임과 FDS 운영 적정성 검사 대상이 될 수 있음. 금융위의 경영진 책임 추궁 방침(2026-11-05)과 연계 가능
- 평판·고객: 법인 고객의 결제 플랫폼 신뢰 저하, 법인카드 재발급에 따른 고객 불편·민원
- 재무·운영: 부정 승인 취소 비용, 재발급 비용, 동일 수법 확산 시 정상 가맹점 명의 청구 탐지 난도 상승

대응 전략

> #### 대응 로드맵
>
> **즉시 (24 시간 이내):** 고위드 경유 당사 법인카드 승인 내역 소급 점검 및 FDS 긴급 룰(정상 가맹점 명의 금액·빈도 급변) 적용 — FDS 운영팀 / 카드승인시스템
>
> **단기 (1~2 주 이내):** 법인카드 대량 등록 B2B 플랫폼 목록화, 제휴 계약에 침해 즉시 통지·관리자 MFA 의무 조항 반영 — 제휴관리팀·법무팀
>
> **중장기 (1 분기 이내):** 제 3 자 플랫폼 경유 거래 전용 FDS 모델(가맹점 행위 기반) 구축, 제 3 자 리스크 관리(TPRM, Third-Party Risk Management) 체계 도입 — 예산·전담 인력 1~2 명 검토(CISO 실·리스크관리부)

5. 관련 출처

- [T4] 한국경제 / 새 빈틈 파고든 해커…금융 플랫폼 통해 법카 부정결제 잇따라 / 2026-11-09 / https://www.hankyung.com/article/2026110960607
- [T4] 매일일보 / 법인카드 관리 플랫폼 해킹… 카드사 여러 곳서 부정결제 시도 / 2026-11-09 / https://www.m-i.kr/news/articleView.html?idxno=2016413
- [T4] 재경일보 / 고위드 해킹에 법인카드 부정결제 시도…금전피해 없어 / 2026-11-10 / https://news.jkn.co.kr/post/1081588

[보고] 자비스 빌링키·카드번호 유출 사고 분석 및 대응 리포트

1. 사고 개요 및 규모

- 발견 시점: 2026-11-05 (운영사 세무법인 에스브이 확인 — 초기 사칭 메일 안내 후 실제 침입 확인)
- 유출·피해 규모: 유출 인원 조사 중, 무단결제 15 건(전액 취소·환불)
- 피해 항목: 대표자·임직원 개인정보, 급여 정보, 카드번호, 정기결제용 빌링키, 공동인증서 정보(비밀번호·개인키 포함 여부 미공개)

2. 사고 원인 및 경위

- 공격 유형: 외부 불법 접근(세부 기법 조사 중) — 확인된 결과는 T1657 Financial Theft(무단결제)
- 기술적 원인: 조사 중(외부 전문가 조사) / 관리적 원인: 결제 키·인증서 정보를 서비스 내 보관한 구조의 보호 수준 조사 중
- 발견 배경: 해커의 운영사 사칭 메일 발송으로 인지 → 실제 침입 확인, 2026-11-06 보도
- 발생 추정 시점: 2026-11-02~2026-11-05 (데일리시큐)

3. 현재 대응 상황

- 즉시 대응: 자비스 서비스 전체 일시 중지, 모든 결제 거래 차단
- 보안 강화: PG 사 협의로 빌링키 폐기, 무단결제 15 건 취소
- 유관기관 신고: 개인정보보호위원회·KISA 유출 신고 완료

4. 경영진 제언

비즈니스 리스크

- 법적·규제: 유출 카드로 부정사용 발생 시 여신전문금융업법상 카드사 보상 책임 쟁점(조문 확인 필요). 당사 고객 정보는 당사 보유분이 아니므로 직접 신고 의무는 없으나, 부정사용 대응 적정성은 감독 대상
- 평판·고객: 유출 대표자 정보를 이용한 카드 재발급·한도 상향 사칭 시 고객 피해 및 민원 확대
- 재무·운영: 비대면 부정결제 보상 비용, 대상 카드 선제 재발급 비용(대상 규모 확인 후 산정)

대응 전략

> **대응 로드맵**
>
> **즉시 (24 시간 이내):** 자비스 가맹점 결제 이력 보유 당사 카드 추출, 비대면 결제 모니터링 강화 — FDS 운영팀
>
> **단기 (1~2 주 이내):** 대상 고객 재발급 안내 여부 결정, 법인 대표자 명의 변경·재발급 요청 시 추가 본인확인 — 고객센터·소비자보호부
>
> **중장기 (1 분기 이내):** 빌링키(카드 토큰) 발급 가맹점별 위험도 관리 및 토큰 즉시 폐기 연동 프로세스 PG 사와 수립 — 결제서비스팀·정보보호부

5. 관련 출처

- [T3] 데일리시큐 / 세무·경리 플랫폼 자비스 해킹, 기업 대표자 주민번호부터 급여·결제·공동인증서 정보까지 유출 우려 / 2026-11-06 / https://www.dailysecu.com/news/articleView.html?idxno=209356

- [T3] 보안뉴스 / '사칭'이라던 자비스, 실제 뚫렸다... 공동인증서·결제 정보 등 유출 확인 / 2026-11-06 / https://www.boannews.com/news/articleView.html?idxno=147080
- [T3] 보안뉴스 / 세무 솔루션 '자비스' 사칭 해킹 발생... 운영사, 서비스 일시 중단 후 점검 / 2026-11-05 / https://www.boannews.com/news/articleView.html?idxno=147073

부록 — SECTION 2 수록 사건 출처

사건	Tier / 출처 / 일자 / URL
MS 11 월 정기패치(Outlook 제로데이·Entra)	[T3] BleepingComputer / Microsoft November 2026 Patch Tuesday fixes 1,235 flaws, Outlook zero-day / 2026-11-10 / https://www.bleepingcomputer.com/news/microsoft/microsoft-november-2026-patch-tuesday-fixes-1-235-flaws-outlook-zero-day/ [T2] Cisco Talos / Microsoft Patch Tuesday for November 2026 / 2026-11-10 / https://blog.talosintelligence.com/microsoft-patch-tuesday-for-november-2026/ ※ 총 수정 건수는 집계 기준에 따라 1,093~1,235 건으로 상이. Outlook CVE-2026-124194(CVSS 6.5)는 조작된 메시지 파일로 NTLMv2 해시 탈취(T1187 Forced Authentication), KEV 2026-11-10 등재. Entra CVE-2026-109469(CVSS 10.0)는 미악용.
섹타나인 PG 가맹점 관리자 계정 침해	[T3] 보안뉴스 / '해피포인트 운영사' SPC 그룹 산하 섹타나인 개인정보 유출 / 2026-11-12 / https://www.boannews.com/news/articleView.html?idxno=147199 [T4] 서울경제 / 섹타나인, PG 서비스 이용 고객 개인정보 추가 유출 / 2026-11-12 / https://m.sedaily.com/article/20113378 ※ 2026-11-06 가맹점 관리자 계정 침해, 구매자명·마스킹 카드번호·카드사 유출, 비밀번호·CVC 유출 미확인.
Storm-3358 ARTEX 금융기관 공격	[T2] Microsoft Threat Intelligence / ARTEX abuse expands as cybercriminals target financial sector / 2026-11-06 / https://www.microsoft.com/en-us/security/blog/2026/11/06/artex-abuse-expands-as-cybercriminals-target-financial-sector/ [T3] Cybersecurity Dive / https://cybersecuritydive.com/news/financially-motivated-threat-ai-tools-banking-artex/874116 ※ 캄보디아 기반 금전 목적 클러스터, 익명 파일업로드·SSRF 악용(T1190) 후 WISP·vshell·AdaptixC2 RAT 설치(T1219). 피해 기관명·수 미공개.
특별대응기간 12 월 말 연장	[T1] 금융위원회·금융감독원 보도자료(KDI 경제정보센터 게재본) / 2026-11-06 / https://eiec.kdi.re.kr/policy/materialView.do?num=289165&topic=P [T4] SBS Biz / 금융당국, 개인정보 유출 특별대응기간 연말까지 연장 / 2026-11-06 / https://biz.sbs.co.kr/amp/article/20000344714
가상자산업권 보안대책	[T4] 한국경제 / 가상자산 해킹 의심만 되도, 선제적으로 입출금 차단 / 2026-11-12 / https://www.hankyung.com/article/2026111235541 [T4] 한국경제 TV / 금융위 "해킹 의심 땐 선제 차단" / 2026-11-12 / https://www.wowtv.co.kr/NewsCenter/News/Read?articleId=A202611120036
全금융권 보안체계 혁신방안	[T4] 시사저널 e / 금융권 해킹 한 달 새 40 건…당국, 580 개사 보안체계 전수점검 / 2026-11-05 / https://www.sisajournal-e.com/news/articleView.html?idxno=424837 [T4] 헤럴드경제 / 금융권 한달 새 해킹 정보유출 47.3 만건…자금 탈취 10 억원 신고 / 2026-11-05 / https://biz.heraldcorp.com/article/10926424 ※ 2026-09-30~11-03 금융회사 37 곳 침해사고 40 건(여신전문금융업 2 곳 포함), 정보유출 약 47.3 만 건, 자금탈취 약 10 억 원.
Binance 탈취자금 세탁 정황	[T2] Elliptic / North Korea is minting meme coins to launder the Binance hack / 2026-11 / https://elliptic.co/insights/north-korea-meme-coins-binance-hack [T4] Gizmodo / https://gizmodo.com/north-korea-is-using-elon-musk-themed-memecoins-to-launder-crypto-from-the-binance-hack-2000837160 ※ 공격 주체 귀속은 Elliptic 분석 기준이며 본 보고서는 독자 검증하지 않음.
SnakeKeylogger 견적서 위장 피싱	[T2] AhnLab ASEC / 견적서 문의를 위장한 피싱 메일 주의 (SnakeKeylogger) / 2026-11-12 / https://asec.ahnlab.com/ko/96494/ (⚠ 단일 소스, T1566.001·T1059.001)

자체검증 결과

> **[자체검증 결과]**
>
> ① 논리적 비약 여부: 없음 — 심각도는 기준표 조건(KEV+실악용, 직접 금전피해, 카드 승인 영향)에 근거해

부여. 금융보안원 해킹은 대규모 유출·결제 영향 요건 미충족으로 HIGH 로 분류하되 금융권 직결로 SECTION 6 에 수록.

② 추측성 표현 여부: 없음 — 사건 개요·메타데이터는 공식 발표·보도 사실만 기술하고 미확인 항목은 "조사 중/미공개"로 표기. 금융보안원 해킹과 금융권 연쇄 침해 간 연관성은 확인되지 않아 기술하지 않았으며, Binance 사건 공격 주체 귀속은 "Elliptic 분석 기준, 독자 검증하지 않음"으로 한정.

③ 실무 적용 가능성: 적합 — 모든 조치에 담당 부서·기한 명시. 단, 부서명은 일반 직제 기준으로 기재하여 당사 실제 조직명 매핑 필요.

④ 출처 검증 상태: ✅ 확인 14 건 / ⚠ 미확인 1 건(ASEC SnakeKeylogger). ※ 수집 환경의 네트워크 정책상 기사 원문 직접 열람이 제한되어, 교차확인은 다수 매체 검색 결과 요약 기반으로 수행함. 피해 수치는 원문 재확인 권장.

⑤ 날짜·기간 기준 검증: KST 기준 2026-11-06~11-12 충족, 예외 4 건 — (1) Crédit Mutuel Arkéa: 최초 공개 2026-11-04, 피해액 후속 보도 2026-11-09 로 기간 내 갱신 (2) 全금융권 보안체계 혁신방안: 2026-11-05 발표이나 당사 전수점검 기한(2026-11-30) 직결로 수록 (3) 자비스: 침해 인지 2026-11-05, 보도 2026-11-06 (4) 고위드: 침해 2026-10-27, 최초 공개 2026-11-09. Entra CVE-2026-109469 는 2026-11-05 공개이나 11-10 정기패치 항목에 통합.

※ Tier 별 탐색 결과: 개인정보보호위원회·과기정통부·국가사이버안보센터·NIST·ENISA — 해당 기간 특이사항 없음. CISA Barracuda 패치 기한·CVE-2026-123158 CVSS 점수 — 확인 중. Cisco BroadWorks(CVE-2026-20320) KEV 등재는 독립 확인 불충분으로 미수록.

침해사고대응팀 · 생성형 AI 자동 수집·분석 · 2026-11-12

출처: [Tier 1] CISA KEV 알림(11-06·11-09·11-10), KISA 보안공지(OpenSSH 11-07), 금융위원회·금융감독원 보도자료(11-06) / [Tier 2] Microsoft Threat Intelligence, Cisco Talos, AhnLab ASEC, Elliptic / [Tier 3] 보안뉴스, 데일리시큐, BleepingComputer, SecurityWeek, Help Net Security, Security Affairs, Hackread / [Tier 4] 한국경제, 뉴스 1, 서울신문, 알파경제, 매일일보, 재경일보, 서울경제, 헤럴드경제, 시사저널 e, SBS Biz